Vulnerability Assessment for [redacted]

OSINT and Groundwork Phase:

The purpose of this report is to create a high level picture of [redacted]'s security posture and risk/vulnerability condition. It will assess and inform on his digital footprint, physical device and home security, network integrity, and ensure the confidentiality, integrity, and availability of his accounts, devices, network, and services. The report will begin with an open source intelligence research phase, digging into [redacted]'s online footprint to attempt to find information that could be useful to attackers, should they choose to perform a targeted (spear phishing) attack.

High-level findings

- Identity & career footprint: Multiple official USACE pages name "[redacted] as an [redacted] (retirement article and official image).

- Public work email (historical) appears in USACE materials and releases (format: firstname.m.lastname@usace.army.mil), alongside an office phone and the old downtown office address (in a USACE planning PDF). These are legacy but still searchable.

- Social presence: A Facebook profile lists "[redacted]," plus schooling history.

- Professional profile: A LinkedIn page lists him as a retired USACE project manager in Omaha.

- Images: Official retirement and historical USACE photos identify him by name and role (useful for face-matching risks).

- Political donations: Public FEC aggregators list multiple small contributions in April 2020 under "[redacted] C. [redacted]," with ZIP XXXXX. This is sensitive but public by law; it increases data-broker linkage risk.

- People-search/data-broker traces: Aggregator pages show a record for "[redacted] C [redacted]," with partially exposed emails, phones, and street names (redacted here).

These sites typically resell to dozens of partners. Accurate birthday, marriage status, income and net worth, etc are listed on data broker sites. One example of these is below and appears to be highly accurate:

[redacted]

Public Biographical Details

- **Career history** – [redacted]. This confirms his long tenure and expertise in environmental planning.

- **Community work** – The same article credits him with volunteering for special assignments, mentoring colleagues and providing technical reviews for state-funded environmental projects. These details could be used by social-engineers to craft convincing communications referencing his past projects.

- **Retirement status** – [redacted], and that he intended to spend more time with family, gardening and travelling. This timeline could help an attacker guess his availability or interests.

Online/social-media presence

- **Facebook** – Search results show a Facebook profile listed as "[redacted] – [redacted]" Although I couldn't open the Facebook page, the snippet suggests he publicly lists his past employer and education. Personal details on social media can be mined for

spear-phishing (redacted).

- **LinkedIn** – A LinkedIn search result hints that there are multiple "[redacted] [redacted]" profiles. This was in fact determined to be his profile, which further lists his work and education history, as well as volunteer experience and spoken languages. It also opens the door to potentially connecting with him there under false pretenses.
- **Instagram** – A post from "@[redacted]" declares: "On Sunday, Master Gardener and newly awarded Environment Champion, [redacted] [redacted] redacted quote info"

Political donations and address exposure

- **Federal Election Commission data** – City-Data's compilation of FEC records shows that a "[redacted] C. [redacted] (Job title redacted)" in zip code **XXXXX** made several small contributions ([redacted]. This confirms a public political-donor record associated with his name, job title and approximate neighborhood.

Sources and Images

[redacted]

Photos found online included here for reference but redacted for privacy.

Data Breach Research:

Status: The email [redacted] **has been found in nine data breaches** (haveibeenpwned.com).

Breaches listed:

1. **National Public Data (Apr 2024)** – Unverified breach of background check service; exposed extensive personal info including SSNs, DOBs, addresses, and phone numbers.

2. **Luxottica (Mar 2021)** – Eyewear giant; data of ~70M leaked including names, addresses, DOBs, genders, phone numbers.

3. **Zynga (Aug 2019)** – Game developer; 173M users' emails, usernames, and passwords exposed.

4. **Verifications.io (Feb 2019)** – Email validation service; 763M emails with personal info leaked.

5. **Collection #1 (Jan 2019)** – Massive credential-stuffing list with 773M unique emails and passwords.

6. **Exactis (May 2018)** – Marketing firm leak with 340M detailed personal records.

7. **Houzz (May 2018)** – Home design site; 49M accounts exposed with emails, IPs, and passwords.

8. **MyFitnessPal (Jan 2018)** – 144M user accounts breached; included usernames, emails, hashed passwords.

9. **Adobe (Oct 2013)** – 153M users affected; emails, encrypted passwords, and password hints leaked.

Paste record: One listing titled *demo.zeeroq.com* with 704,270 emails.

[redacted]@gmail.com did not turn up in any data breaches

[redacted]@gmail.com showed up in the same Houzz.com data breach (as above) in 2018 that exposed email addresses, geographic locations, IP addresses, names, passwords, social media profiles, and usernames.

Summary of OSINT Findings

It is evident that there is a great deal of easily available public information about you online. This includes accurate address, birthdate, relatives, and even income and net worth. There are photos and biographical articles on the Army Corps website that attackers could easily use to craft detailed phishing messages. Your primary email address has appeared in numerous data leaks, indicating that it may not be secure and that a password change at least is warranted if it has not been changed since the most recent leak (2024). It is also crucial that this email be protected with multi-factor authentication.

Social media profiles also are visible publicly and include information such as your prior work, education, and interests. These further make phishing attacks possible and convincing. Further, there is information that is easily discoverable about political affiliation and donation histories to political groups (notably REDACTED for Congress). Attackers might also use images to reverse image search using available tools, though this is unlikely to yield significant results and was not deemed necessary for this report.

Recommendations are to ensure privacy of social media profiles, and verify that the email address [redacted] is protected by multifactor authentication and a secure, complex, recent password. Be wary of phishing attempts that may claim to have information about your prior work (in great detail thanks to USACE articles), gardening interests (due to social media posts), or have great detail about your address, relatives, phone number, etc. (largely because of data broker websites). It would be prudent to engage in the process of cleaning up your footprint from data broker sites, which can sometimes be expensive or time consuming, but would help prevent unwanted solicitation and possible spear-phishing attacks.

Device and Account Security Methods

Devices:

1. Windows 11 Laptop: PIN secured
2. Windows 11 Desktop: PIN secured
3. Samsung Phone: Face scan and PIN secured

Accounts:

1. Amazon: Automatic login on phone, 2FA for new devices
2. Coinbase: [redacted] username, automatic login with 2FA text
3. Fidelity: Username is [redacted], secured with biometric login and uses a unique password. 2FA with new devices only.
4. IRS ID.ME: [redacted]@[redacted].net, no further details provided
5. Microsoft: Unique password, possible 2FA on new devices
6. [redacted]NEST: Username is [redacted] and uses a unique password stored in phone's password manager, 2FA text message validation each time
7. Omaha Community Fnds: Username is [redacted] and has a unique password updated nearly every time
8. Paypal: Username is [redacted] (not secure), accessed with a fingerprint and unique password, not protected by 2FA each login.
9. [redacted]US Bank: [redacted] is the username, accessed with a fingerprint and unique password
10. Principal: Username is [redacted], accessed with a unique password, 2FA text or email each time

Password Storage:

1. Saved in Excel file
2. Passwords are stored in an unlocked file folder next to PC
3. Wifi Password is default for router and printed in plaintext on router itself
4. Saved by Google's password manager
5. Saved on Samsung phone's password manager

Immediate action is required on the first three items above, these practices are extremely insecure and create high potential for account breach. See summary for details and instructions on resolving these critical vulnerabilities.

Otherwise his practices are relatively secure. MFA should be used on all accounts with high importance or financial information/access.

Home Network Security Review – Summary

Router (192.168.0.1)

- **Findings**

    1. Still using the default admin login (`admin / password`). **Fixed immediately upon reporting.**

    2. "UPnP" service is active (automatically opens ports; common attack path). Can be disabled from router console

    3. Web admin pages use **old encryption** (weak TLS settings).

    4. "Slowloris" flaw possible—could freeze the web UI from inside the network.

    5. Cross-Site Request Forgery (CSRF) weakness on login form—only relevant if someone on the network is tricked into clicking a link.

    6. Firmware appears outdated.

    7. Determined that the network uses WPA2 encryption. This is acceptable but

       ideally would use WPA3 for future proofed secure communication.

- **Fixes**

    1. Change router admin username/password immediately.

    2. Update router firmware (or have Cox push the update).

    3. Disable **UPnP** and **WPS**.

    4. Keep admin access **LAN-only** and ideally **wired-only**.

    5. Rename the Wi-Fi network and set a **new strong passphrase** using **WPA2 or WPA3**.

    6. If available, disable "remote management" and "allow guests to access local network."

7. After saving settings, re-scan to confirm ports 49152 and 1900 are closed.

Other Devices on the Network

Device	What It Is	Main Risk	Recommended Action
HP printer (192.168.0.59)	Network printer	Web admin and raw print port (9100) open	Add admin password, disable raw 9100, use secure IPP (443/631)
Google Home / Nest devices (140, 228, 246)	Smart speakers/displays	Exposed media/control ports	Put on separate **Guest/IoT network**
Android phone (192.168.0.53)	Personal device	Normal, but can see router if compromised	Keep updated and protected
Orbit irrigation controller (218)	Smart sprinkler	Weak embedded OS	Move to IoT network
Unknown devices (154, 224)	Possibly other IoT/phones	Unknown	Identify or remove

Network Layout Issues

- All devices share one flat local network, so if one is hacked (like a TV or printer), everything else is exposed.

Fix

- Create a **Guest/IoT network** for all smart devices, printers, and irrigation controllers.
- Keep computers and phones on the **main secure network**.
- Turn on “client isolation” or “block access to local network” on the guest network.

Overall Risk Rating

Severity	Items	Description

Critical	Default router password	Gives anyone on Wi-Fi full control
High	UPnP enabled, weak TLS	Could open backdoors or leak info
Medium	Flat LAN with IoT, printer web admin open	Easier lateral attacks
Low	Slowloris, CSRF, SMB visible	Minor in home context

Priority Order

1. Change all router and Wi-Fi passwords. **Done.**
2. Disable UPnP, WPS, and remote management on the router console.
3. Update router firmware.
4. Make a separate Guest/IoT network.
5. Secure printer and disable unnecessary ports.
6. Re-scan to confirm the fixes worked.

Summary

Other than the initial, highly insecure practice of utilizing the default admin and wifi credentials for his network, [redacted] network is mostly secure. Minor to moderate vulnerabilities exist with the availability of UPnP, out of date router firmware, and a single network that includes IoT devices, but these are not likely to result in a significant breach on a home network. Further, it was confirmed that his credentials were immediately updated, and that his network is not reachable by public internet.

In its current state, his network is relatively secure and does not require immediate action. The actions listed here are complex and require access to the admin panel, which he currently does not have. Remediation can be performed by myself as part of the clean up/remediation phase of the project, but would require [redacted] to first of all regain access to his wifi admin panel. Home wifi networks are further not a regular cause of personal cybersecurity incidents, as phishing attacks through text, phone, or email continue to (by far) dominate the threat landscape.

Physical Security Review

Findings:

1. The building utilizes bolt locks on all doors, relatively easy to physically defeat without reinforcement but still solid. Some doors have double locks and glass windscreen layers, offering a minimal improvement.
2. Multiple windows at ground level that are easily broken into when the building is vacant, but when locked offer reasonable protection.
3. Security cameras watching major points of entry, and covering large portions of the front and back yard are thoughtful improvements, but found disconnected from the network during my assessment.
4. Smart lock on the back garage door offers enhancements, but also weakness if compromised. Ensure adequate security on related account and device integrity through updates and regular battery swaps.
5. Unlocked file folder drawer next to the PC station is a critical vulnerability. Especially considering a folder containing plaintext passwords, unlocked and easily found within seconds.
6. Lack of a modern alarm system on the entry points is a small vulnerability, could be enhanced for minimal cost.
7. Safe neighborhood, but no fencing or gates, community cameras or security patrols leave weakness and opportunity for predators.
8. Devices around the home are generally insecure. Laptops left laying in the open, possibly unlocked and easily stolen (likely without drive level encryption). Phones too, but these are at least PIN or biometric protected.
9. Lack of physical protection should an (unlikely) at home intrusion occur. Defense tooling such as firearms, pepper spray, tasers, and other less lethal options greatly improve defensibility, but should be kept and used with care.
10. Tesla parked in a secure garage when not in use, secure but consider key safety when not at home or asleep.

Suggestions:

1. **Absolute priority** – remove and eliminate the plaintext password file. Destroy this folder securely (shredding, fire) and change all listed passwords on related accounts.
2. Reassign IP cameras to a valid wifi network to resume constant monitoring in case of incidents, or to check home condition remotely.
3. Consider reinforcement of windows and doors to prevent break ins, also possible alarm system investment.
4. Consider purchasing drive level encryption solutions for devices that contain sensitive data (Windows Pro with Bitlocker or similar), and otherwise physically secure sensitive devices when not in use by storing them in hidden or locked compartments.
5. Consider investing in home defense solutions, including non-lethal options such as pepper spray canisters and ranged impact, OC, or shock weapons.

Summary, Findings, and Remediation

Overall, [redacted] maintains a secure home environment, with minimal immediate need for remediation. However, there remain a few exceptions to this. He immediately corrected a severe vulnerability with default credentials on his home network, but there remain two glaring password storage practices that must be resolved. Further, he maintains a legacy email as his primary, which has appeared in numerous data breaches. Finally, he remains vulnerable to phishing attacks (and targeted, spear phishing attacks due to his long career history that is publicly available online). A more thorough breakdown of the top vulnerabilities and remediation steps is listed below:

Top 10 risks

1. Plaintext password list stored next to the PC (critical).
2. Legacy email ([redacted]) in multiple public breaches; likely reused/old credentials (critical). Old, exposed emails are more likely to be used for phishing attacks.
3. Router previously on factory Wi-Fi/admin credentials; UPnP enabled; firmware likely outdated (high).
4. MFA type/coverage gaps: PayPal no enforced MFA; Coinbase using email/SMS for new devices only (high).
5. Single flat LAN with IoT + printer on the same segment (medium).
6. Auto-login on phone (Amazon, possibly others) + browser/phone keychain storage (medium).
7. Public OSINT surface: full name, age, address area, work history, photos, political donations (medium; spear-phish risk). Refresh phishing awareness routinely.
8. Non-encrypted Windows drives (Windows Home) (medium).
9. Disconnected cameras (reliability gap) (low).
10. Physical: laptops and phones visible, unlocked storage, easy window/door entry points (low).

What's Secure:

- Clean asset map (devices + key accounts).
- Many services do have some form of second factor.
- From his home, IPv6 probes had no route to the target; suggesting no easy inbound path.
- High phishing awareness
- Router and wifi credentials updated
- Safe neighborhood and secure practices like locking windows and doors at night or when not at home

Remediation (ranked by criticality)

1. Destroy plaintext password folder and Excel file; migrate everything into one or two password managers (such as Google password manager).
2. Lock down email (cox.net + both Gmail): new long passwords, app-based MFA, remove SMS two factor authentication, purge forwarding rules, sign out all sessions.
3. Coinbase + PayPal: switch to authenticator (or hardware key) MFA; remove email/SMS-only login confirmations as these methods can be spoofed or hijacked.
4. Refresh phishing awareness; remember that much of your personal information is online and attackers may use this to create believable emails or calls. Never give out account information or use MFA confirmation with anyone, especially bank information. Refresh this in your mind routinely and examine all emails carefully before clicking links (email addresses that are off, unexpected requests for logins). Confirm these practices with Susan and vulnerable others.
5. Router hardening (after regaining admin): change admin login, disable remote admin/WPS/UPnP, update firmware, set long random WPA2/WPA3 passphrase, create Guest/IoT SSID with client isolation.
6. Segment: move printer, Nest/Google Home, Orbit irrigation, cameras to Guest/IoT network.
7. Secure the printer: add admin password, disable raw port 9100, prefer IPP/HTTPS.
8. Replace auto-login on phone with password-manager autofill + device lock only.

OSINT summary (why he's targetable)

- Long, well-documented career with photos and quotes; easy to impersonate colleagues or reference projects.
- Donor records (name + ZIP + employer) and data-broker pages listing age, relatives, addresses.
- Social posts about gardening/speaking—ready-made hooks for spear-phish.
- Mitigation: routine data broker opt-outs; social privacy review; awareness of phishing attacks tailored to his history.

Account posture snapshot (best practices for financial accounts)

- Amazon, Fidelity: multifactor authentication (MFA) only on new devices → switch to "every login"; clear trusted devices.
- US Bank: MFA present; verify app/push (not SMS) and disable "remember this device."
- PayPal: enable authenticator MFA now.
- Coinbase: enforce authenticator app or hardware key; remove email-only verification.
- ID.me/IRS, Principal: confirm one time password methods and recovery codes; verify recovery info.
- Nest/Google/Samsung: keep device PIN/biometric, but move logins to a vault; turn off broad auto-save.

Network posture snapshot

Router: default creds (fixed), UPnP enabled, weak TLS on admin UI, outdated firmware, WPA2 in use (OK; WPA3 preferred but apparently unavailable on current firmware).

Devices: HP printer with open web/9100; Nest/Google Home; Orbit controller; unknowns.

Architecture: a single flat LAN leaves internal movement risk.

External reachability: no IPv6 route from your host; treat as “likely filtered/unreachable,” but still disable remote admin and UPnP.

Physical snapshot

Doors/windows okay but unreinforced; cameras present but offline; no active alarm; laptops visible; no recourse for home invasion attempts; unsecured file drawer with passwords (critical).

Mitigation: lockable storage, bring cameras back online, consider basic alarm or at least door/window sensors, home defense capabilities, keep devices out of sight when away.

Next steps

I can complete as many of these remediation steps as you would like assistance with. We can leave the contract open for the time being while you review and consider desired remediation steps. No further work is warranted on this from my end at this time until your review of this document and security posture are complete.